



Lecture Notes

Security Goals, Authorization and Access Control

Lesson 4: Security and Authorization

Lesson 7: Multi Level Model of Security

How to use these notes

- There is **one note for each of the 49 slides**, in the same order as module3.pdf. A small picture of the slide sits beside each note.
- The notes are written **from teacher to students** in **simple language**: read them aloud as they are, or use them as a guide in your own words.
- Each note takes **at most 2 minutes** to speak (about 140–170 words, roughly 1–1¼ minutes) at a steady classroom pace of about 135 words per minute. The estimate for each slide is shown in its title bar.
- Phrases such as “look at the diagram” tell you when to point at the slide.

Slides	49
Total words	7,535
Estimated talking time	about 56 minutes (without pauses or questions)
Lesson 4	slides 3–26
Lesson 7	slides 27–49

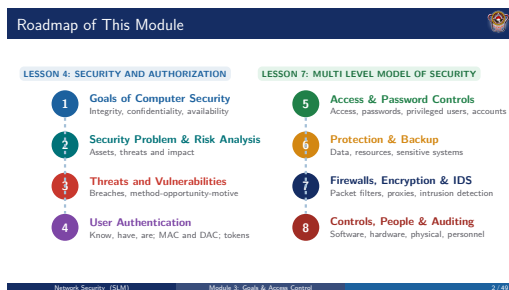


Slide 1 | Title: Security Goals, Authorization and Access Control (about 72 seconds)



Good morning, everyone. Today we start Module 3. The title is Security Goals, Authorization and Access Control. Let me explain these big words in simple language. A goal is simply what we want to achieve. Authorization means giving the right permission to the right person. Access control means deciding who can enter a system and what they can do inside it. Look at the picture on the right. In the middle there is a key, and around it there are rings, like the walls of a fort. People are standing outside the rings. This is the main idea of today's class: we protect our data with many layers, and only the right people get the key. This module has two lessons. Lesson 4 is Security and Authorization. Lesson 7 is the Multi Level Model of Security. Do not worry if some terms sound new. I will explain each one with everyday examples. Just relax, listen carefully, and ask me questions whenever you want.

Slide 2 | Roadmap of This Module (about 69 seconds)



Before we begin, let me show you our road map, so that you always know where we are. On the left side we have four topics from Lesson 4. First, the goals of computer security. Second, the security problem and risk analysis, which means finding out what can go wrong. Third, threats and vulnerabilities, which means dangers and weak points. Fourth, user authentication, which means checking who a user really is. On the right side we have four topics from Lesson 7. We will learn about access control and password rules, then protection and backup of data, then firewalls, encryption and intrusion detection systems, and finally other controls, people and auditing. So the first half tells us what to protect and why. The second half tells us how to protect it. Keep this picture in mind. At any time, if you feel lost, just think: which number on the road map are we on now?

Slide 3 | Lesson 4: Security and Authorization (about 63 seconds)



Now we begin Lesson 4, Security and Authorization. Let me ask you a simple question. When you leave your house, what do you do? You lock the door. Why? Because you have valuable things inside, and you know that someone might try to steal them. You also give a spare key only to people you trust. A computer system is just like your house. It has valuable things inside, mainly data. There are people who may try to steal or damage that data. And we must decide who gets a key. In this lesson we will answer three questions. What are we trying to achieve? What can go wrong? And how do we check that a person is really who they say they are? These ideas are the base of the whole subject, so please pay full attention to this lesson.



Slide 4 | What You Will Learn in Lesson 4 (about 70 seconds)

What You Will Learn in Lesson 4

Know the threats to computer security

Understand what causes these threats

Know various security techniques

The big question

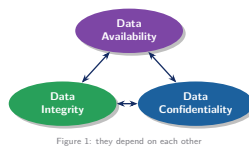
How do we decide **what** to protect, **from whom**, and **how**, and then make sure only the **right people** get in?

- Goals: C, I, A
- Risk analysis in 3 steps
- Threats vs. vulnerabilities
- Authentication and authorization

Let us look at the learning goals of Lesson 4. There are three of them, shown in the coloured boxes on the left. First, you will know the threats to computer security. A threat is simply something that can cause harm. Second, you will understand what causes these threats. When we know the cause, we can stop the problem early. Third, you will learn various security techniques, which are the tools we use to protect our systems. Now look at the blue box on the right. It says the big question is: what do we protect, from whom, and how? And how do we make sure only the right people get in? Below that you can see the four topics we will cover: the three goals called C, I and A; risk analysis in three steps; the difference between threats and vulnerabilities; and finally authentication and authorization. If you understand these four points, you have understood Lesson 4.

Slide 5 | Goals of Computer Security (about 69 seconds)

Goals of Computer Security



- The goals of computer security are **integrity, confidentiality and availability** of the information managed by the system
- The three are **related**: improving one can weaken another

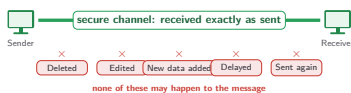
Example of the tension

Locking data away very tightly improves confidentiality, but it can **hurt availability** for the people who need it.

Now we come to the most important idea of this lesson: the goals of computer security. There are three goals. Integrity, confidentiality and availability. Look at the triangle on the left, which is Figure 1 in your study material. Each goal is a coloured circle, and they are connected with arrows. Why the arrows? Because the three goals depend on each other. They are related. If you improve one, you may affect another. Let me give you an example from the green box. Suppose you lock your data very tightly, with ten passwords and many approvals. Confidentiality becomes very strong, because nobody can see the data. But then even the people who need the data cannot get it quickly. So availability becomes weak. This is the challenge in security. We must find the right balance between the three goals. In the next three slides, we will study each goal one by one, starting with integrity.

Slide 6 | Goal 1: Integrity (about 74 seconds)

Goal 1: Integrity



Definition

Data sent through the secure channel is **not altered or tampered** with by others.

Note

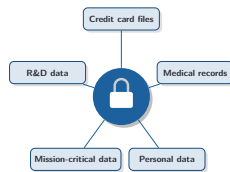
Integrity does **not** stop a third party from viewing the data; it only guarantees nobody modified it.

The first goal is integrity. In simple words, integrity means the data is not changed by anyone who should not change it. Look at the diagram. A sender sends a message to a receiver through a secure channel. The message must arrive exactly as it was sent. Now look at the red boxes below. None of these things should happen to the message. It should not be deleted. It should not be edited. New data should not be added to it. It should not be delayed. And it should not be sent again by someone else. For example, if you send your bank an instruction to pay one thousand rupees, it must not become ten thousand rupees on the way. Now, please read the red box on the right carefully, because students often get this wrong. Integrity does not stop a third person from seeing the data. It only guarantees that nobody has changed it. Hiding the data is a different goal, which we will see next.



Slide 7 | Goal 2: Confidentiality (about 69 seconds)

Goal 2: Confidentiality



Definition

When data travels from source to destination, **nobody except the intended person** can view it.

- A network with no confidentiality is **not secure**
- Minimum requirement: the mail you send a friend is **not read by anyone else**
- If people cannot trust e-mail to be confidential, they **never use it**

The second goal is confidentiality. In simple words, confidentiality means keeping a secret. When data travels from the source to the destination, nobody except the intended person should be able to see it. Look at the lock in the middle of the diagram. Around it are examples of data that must be kept secret: credit card files, medical records, personal data, mission-critical data of a company, and research and development data. Imagine your medical report being read by strangers. You would feel very uncomfortable. That is why confidentiality is so important. Your study material says that a network without confidentiality is not secure at all. The minimum requirement is simple: when you send an email to your friend, nobody else should read it. And here is a practical point. If people cannot trust that their email is private, they will simply stop using email. So confidentiality is not only about security, it is also about trust.

Slide 8 | Goal 3: Availability (about 76 seconds)

Goal 3: Availability

Definition

The system is **accessible to authorized persons at appropriate times**.

Balance

There is no point making a system so secure that **no user can access** the data they need to do their jobs.

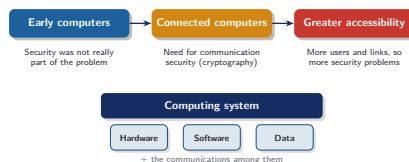
A computer system is available if...

- ✓ The response time is acceptable
- ✓ There is a fair allocation of resources
- ✓ Fault tolerance exists
- ✓ It is user friendly
- ✓ Concurrency and deadlock control exist

The third goal is availability. In simple words, availability means the system works when you need it. The definition in the blue box says the system must be accessible to authorized persons at appropriate times. Think of an ATM. Even if the ATM is very secure, it is useless if it does not give you money when you need it. Now look at the red box. There is no point making a system so secure that no user can access the data they need to do their job. Security must not stop the real work. On the right side you can see five signs of an available system. The response time is acceptable, so it is not too slow. There is fair allocation of resources, so one user does not take everything. There is fault tolerance, so the system keeps working even if one part fails. It is user friendly. And there is proper control of concurrency and deadlocks, so many users can work together without the system getting stuck.

Slide 9 | The Security Problem (about 68 seconds)

The Security Problem



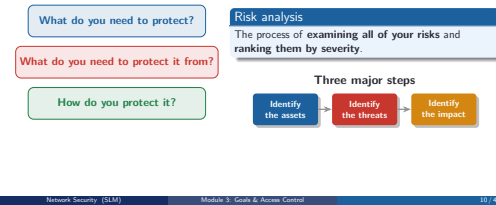
Computer security tries to ensure the **confidentiality, integrity and availability** of these components. Attackers exploit **vulnerabilities** through interception, interruption, modification and fabrication.

Now let us understand the security problem. Look at the three boxes at the top. In the early days, computers worked alone, and security was not really a big problem. Then computers were connected to each other, and we needed communication security, which led to cryptography. Then more and more people got access through networks, so the security problems grew bigger. In simple words, the more doors a house has, the more chances a thief has to enter. Now look at the bottom of the slide. A computing system has three main parts: hardware, software and data, plus the communication between them. Computer security tries to make sure that all these parts keep their confidentiality, integrity and availability. Attackers look for weak points, which we call vulnerabilities. They use four kinds of attacks that you learned in Module 1: interception, interruption, modification and fabrication. So every part of the system needs protection.



Slide 10 | Risk Analysis: Finding Security Problems (about 70 seconds)

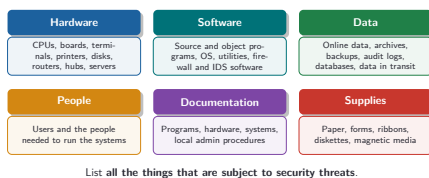
Risk Analysis: Finding Security Problems



How do we find security problems before attackers find them? We do something called risk analysis. Look at the three questions on the left. What do you need to protect? What do you need to protect it from? And how do you protect it? These three simple questions are the heart of risk analysis. Now read the blue box. Risk analysis means examining all your risks and ranking them by how serious they are. Why rank them? Because no organization has unlimited money or time. We must fix the most dangerous problems first. Think of a doctor in an emergency room. The doctor treats the most serious patient first, not the one who came first. On the bottom right you can see the three major steps of risk analysis. Step one, identify the assets. Step two, identify the threats. Step three, identify the impact. In the next few slides we will go through each step one by one.

Slide 11 | Step 1: Identifying the Assets (about 67 seconds)

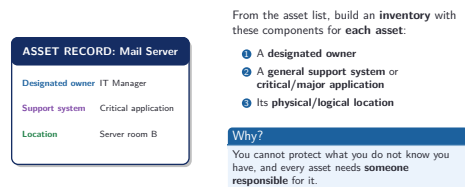
Step 1: Identifying the Assets



The first step of risk analysis is to identify the assets. An asset is anything valuable that can be harmed. We simply make a list of everything that is subject to security threats. Look at the six coloured boxes. First, hardware: CPUs, terminals, printers, disks, routers and servers. Second, software: programs, the operating system, utilities, and security software like firewalls. Third, data: online data, archives, backups, audit logs, databases, and data travelling on the network. Fourth, people: the users and the staff who run the systems. Yes, people are also assets, because without them the system cannot work. Fifth, documentation: manuals about programs, hardware and procedures. And sixth, supplies: paper, forms and storage media. Students often forget people, documentation and supplies. But think about it: if a backup tape is stolen, or a system manual reaches the wrong person, it can cause serious harm. So the list must be complete.

Slide 12 | The Asset Inventory (about 72 seconds)

The Asset Inventory

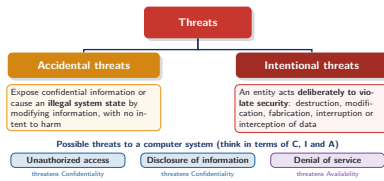


Once we have the list of assets, we make an inventory. An inventory is a proper record of each asset. Look at the sample card on the left. It is a record for a mail server. For every asset, the inventory must have three things, shown on the right. First, a designated owner. In our example, the owner is the IT Manager. The owner is the person responsible for that asset. Second, whether it is a general support system or a critical application. Our mail server is marked as a critical application, which means the business will suffer badly if it stops. Third, its physical or logical location. Our server is kept in Server Room B. Now read the blue box at the bottom. You cannot protect what you do not know you have. And every asset needs someone responsible for it. If everybody is responsible, then in practice nobody is responsible. So every asset must have a name next to it.



Slide 13 | Step 2: Identifying the Threats (about 69 seconds)

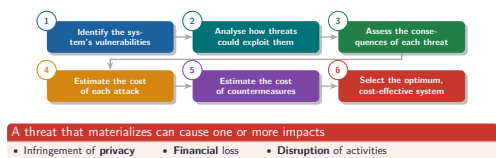
Step 2: Identifying the Threats



The second step is to identify the threats. A threat is something that can harm an asset. Look at the tree. Threats are of two kinds. On the left, in orange, are accidental threats. These happen by mistake, with no intention to harm. For example, an employee sends a confidential file to the wrong email address, or changes some data by mistake and leaves the system in a wrong state. On the right, in red, are intentional threats. Here someone deliberately tries to break the security. They may destroy, modify, create fake data, interrupt the service, or secretly read the data. Now look at the bottom of the slide. Your study material lists three possible threats to a computer system. Unauthorized access and disclosure of information both threaten confidentiality. Denial of service threatens availability. A simple tip: whenever you see a threat, ask yourself which of the three goals, C, I or A, it is attacking.

Slide 14 | Step 3: Identifying the Impact (about 68 seconds)

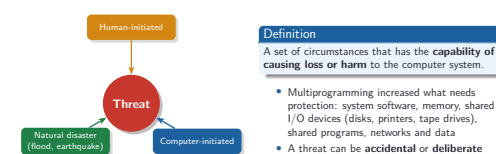
Step 3: Identifying the Impact



The third step is to identify the impact. Impact means the damage that a threat causes if it really happens. Look at the six numbered boxes. We follow them in order. First, find the weak points of the system. Second, think about how a threat could use those weak points. Third, look at the consequences of each threat. Fourth, estimate how much each attack would cost us. Fifth, estimate how much it would cost to protect against it. And sixth, choose the best system that gives good protection at a sensible cost. Step four and step five are very important together. If an attack would cost us one thousand rupees, we should not spend one lakh rupees to stop it. Now look at the red box. When a threat really happens, it can cause one or more of three impacts. Infringement of privacy, financial loss, and disruption of normal work. Please remember these three.

Slide 15 | What Is a Threat? (about 68 seconds)

What Is a Threat?

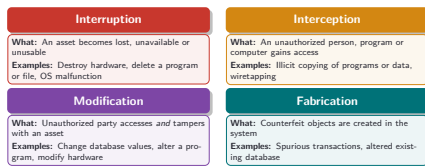


Let us now look more closely at threats. Read the definition in the blue box. A threat is a set of circumstances that has the capability of causing loss or harm to the computer system. Notice the word capability. A threat is something that can cause harm; it may or may not actually happen. Look at the diagram on the left. Threats come from three sources. Human-initiated threats come from people, like hackers or careless employees. Computer-initiated threats come from machines or software, like a program that goes wrong. And natural disasters like floods and earthquakes are also threats. Now look at the bullet on the right. In older days a computer ran one program at a time. With multiprogramming, many users share the same memory, disks, printers and programs. So more things need protection. Finally, remember that a threat can be accidental or deliberate, as we saw on the previous slides.



Slide 16 | Four Kinds of Security Breach (about 66 seconds)

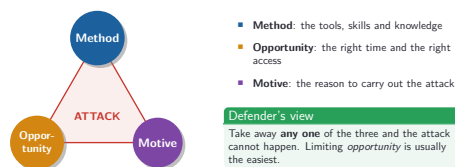
Four Kinds of Security Breach



A breach means the security has actually been broken. Your study material describes four kinds of breach. You already know these names from Module 1, so let us connect them to real examples. Top left is interruption. An asset becomes lost, unavailable or unusable. Examples are destroying hardware, deleting a program or file, or the operating system failing. Top right is interception. An unauthorized person, program or computer gets access to the asset. Examples are illegally copying programs or data, and wiretapping. Bottom left is modification. Here the attacker not only gets access, but also changes the asset. Examples are changing values in a database, altering a program, or modifying hardware. Bottom right is fabrication. The attacker creates fake objects in the system. Examples are adding false transactions or false records to a database. A simple way to remember: interruption stops, interception reads, modification changes, and fabrication creates.

Slide 17 | What Does an Attacker Need? M–O–M (about 69 seconds)

What Does an Attacker Need? M–O–M



Here is a simple but powerful idea. To carry out an attack, an attacker needs three things. We call them M, O, M. Look at the triangle. The first M is method. This means the tools, skills and knowledge needed for the attack. The O is opportunity. This means the right time and the right access to the system. The second M is motive. This means the reason for the attack, like money, revenge or fame. Think about an ordinary theft. A thief needs to know how to break a lock, which is the method. The house must be empty, which is the opportunity. And the thief must want something inside, which is the motive. Now read the green box. As defenders, if we take away any one of these three, the attack cannot happen. In practice, the easiest one to remove is usually opportunity. We do that by limiting access and closing weak points.

Slide 18 | Threat, Vulnerability and Control (about 70 seconds)

Threat, Vulnerability and Control

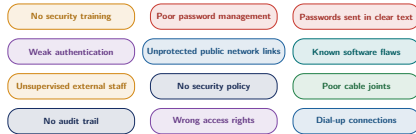


This slide connects three key words: threat, vulnerability and control. Look at the diagram from left to right. On the left is a threat. On the right is our system, with hardware, software and data. On the edge of the system you can see a small red mark labelled weakness. That weakness is a vulnerability. The threat tries to exploit, or use, that weakness. Read the red box. A vulnerability is a weakness in the system. It does no harm by itself until someone exploits it. It can be in the procedures, the design or the implementation. Now look at the green box in the middle of the diagram. That is a control. A control is an action, device, procedure or technique that removes or reduces the vulnerability, and so it blocks the threat. Here is an example. An open window in your house is a vulnerability. A thief is a threat. A window grill is a control.



Slide 19 | Everyday Vulnerabilities (about 71 seconds)

Everyday Vulnerabilities

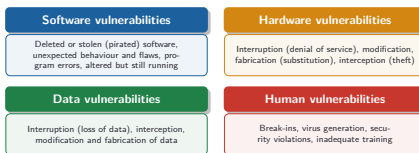


Also: inadequate recruitment procedures, insufficient preventive maintenance, inadequate system management.

This slide shows common weak points that we see in real organizations. Let me read a few of them with you. No security training: staff do not know what is safe and what is dangerous. Poor password management, and passwords sent in clear text, which means without encryption, so anyone listening can read them. Weak authentication, so it is easy to pretend to be someone else. Unprotected public network links. Known software flaws that were never fixed. Outside staff working without supervision. No security policy at all, so nobody knows the rules. Poor cable joints that someone can tap. No audit trail, so nobody can find out what happened later. Wrong access rights, where people have more permission than they need. And old dial-up connections. At the bottom, the study material adds poor hiring procedures, too little preventive maintenance, and poor system management. As you can see, many vulnerabilities are not technical at all. They come from people and processes.

Slide 20 | Vulnerabilities by Component (about 68 seconds)

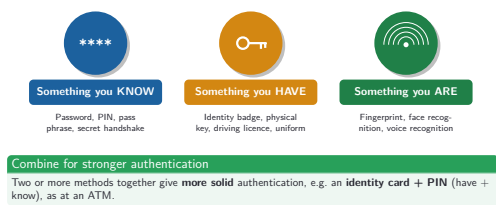
Vulnerabilities by Component



Let us organize vulnerabilities by the part of the system they affect. Look at the four boxes. Top left is software. Software can be deleted, or stolen, which we call piracy. It can have flaws and behave in unexpected ways. It can have program errors. Or it can be secretly altered and still look like it is running normally. Top right is hardware. Hardware can be interrupted, for example a cable is cut and service is denied. It can be modified, a fake device can be substituted, which is fabrication, and it can be stolen, which is interception. Bottom left is data. Data can be lost, intercepted, modified or faked. Bottom right is the human side. People can break in, create viruses, break security rules, or simply make mistakes because of poor training. Notice again that the same four attacks, interruption, interception, modification and fabrication, appear for every part of the system.

Slide 21 | User Authentication: Three Qualities (about 69 seconds)

User Authentication: Three Qualities

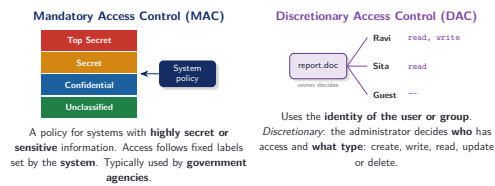


Now we move to user authentication. Authentication means checking that a user is really who they claim to be. There are three ways to do this. Look at the three circles. The first is something you know. This could be a password, a PIN, or a pass phrase. The second is something you have. This could be an ID card, a physical key, a driving licence or even a uniform. The third is something you are. This means your body, such as your fingerprint, your face or your voice. Each method alone has a weakness. A password can be guessed. A card can be stolen. Now read the green box. When we combine two or more methods, authentication becomes much stronger. A very common example is your ATM. You need your card, which is something you have, and your PIN, which is something you know. A thief with only the card cannot take your money.



Slide 22 | Who Has Access to What? MAC vs. DAC (about 69 seconds)

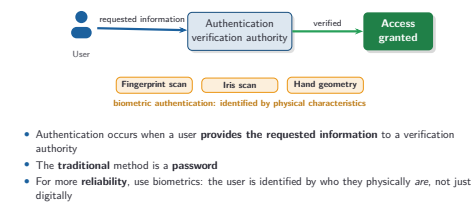
Who Has Access to What? MAC vs. DAC



After we know who the user is, we must decide what they are allowed to do. There are two main approaches. On the left is Mandatory Access Control, or MAC. Here, information is given fixed labels like Top Secret, Secret, Confidential and Unclassified, as you see in the coloured bars. The system policy decides who can see what. Even the owner of a file cannot change this. MAC is used where information is highly sensitive, mainly in government and defence. On the right is Discretionary Access Control, or DAC. Here access depends on the identity of the user or group. Look at the example. For the file report dot doc, Ravi can read and write, Sita can only read, and a guest cannot do anything. The word discretionary means the administrator or owner decides who gets access and what type of access, such as create, read, write, update or delete. Most office computers use DAC.

Slide 23 | Authentication and Biometrics (about 66 seconds)

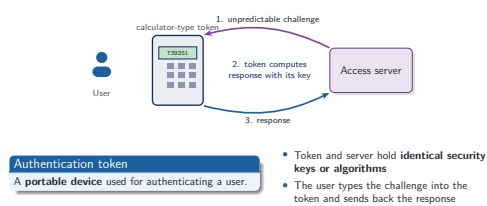
Authentication and Biometrics



Let us see how authentication works step by step. Look at the diagram. A user gives the requested information, like a password, to an authentication authority. The authority checks it. If it is correct, access is granted. The traditional method is a password. But passwords can be stolen or guessed. So for better reliability, we use biometrics. Biometric authentication identifies a person by their physical features. Look at the three orange boxes: fingerprint scan, iris scan, which looks at the coloured part of your eye, and hand geometry, which measures the shape of your hand. You already use biometrics every day. When you unlock your phone with your fingerprint or your face, that is biometric authentication. Even our Aadhaar system uses fingerprints and iris scans. The big advantage is that you cannot forget your finger at home, and it is very hard for someone else to copy it.

Slide 24 | Hardware Token: Challenge and Response (about 68 seconds)

Hardware Token: Challenge and Response

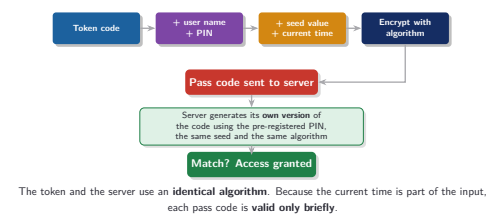


Another way to authenticate is with an authentication token. A token is a small portable device used to prove your identity. Look at the diagram. In the middle is a calculator-type token. On the right is the access server. Let us follow the numbers. Step one: the server sends the user an unpredictable challenge, which is like a random question. Step two: the user types the challenge into the token, and the token calculates a response using its secret key. Step three: the user sends that response back to the server. Now, the important point in the bullet: the token and the server have identical keys or algorithms. So the server can calculate the correct response itself and compare. If they match, the user is genuine. Because the challenge is different every time, an attacker who copies one response cannot use it again. This is much safer than sending the same password every day.



Slide 25 | Hardware Token: Time-Based (about 65 seconds)

Hardware Token: Time-Based

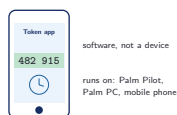


Network Security (SSM) Module 3: Goals & Access Control 25 / 49

Some tokens work using time instead of a challenge. Follow the diagram from left to right. The token takes its token code, the user name and PIN, a seed value and the current time. It encrypts all of these together using an algorithm. The result is a pass code, which is sent to the server. Now look below. The server already knows the user's PIN, the same seed, and the same algorithm. So it generates its own version of the code. If the two codes match, access is granted. Why include the time? Because the time keeps changing, the pass code changes every short while, often every 30 or 60 seconds. So even if someone sees your pass code, it becomes useless very quickly. You may have seen this when a bank or app shows a six-digit code that keeps changing. That is exactly this idea.

Slide 26 | Software Tokens (about 69 seconds)

Software Tokens



Software token
An authentication process using **portable devices** (Palm Pilot, Palm PC, wireless telephone) that carry the **embedded software**.

- Chosen when an organization does **not wish to buy hardware tokens**
- Today's authenticator apps on smartphones are modern software tokens

Network Security (SSM) Module 3: Goals & Access Control 26 / 49

Finally, let us talk about software tokens. Instead of carrying a separate hardware device, the token is a piece of software that runs on a portable device that you already own. Your study material mentions devices like the Palm Pilot, Palm PC and wireless telephones. These are older devices, but the idea is the same today. Look at the picture of the phone. A token app shows a code that changes regularly, just like the hardware token. Why do organizations choose software tokens? As the bullet says, it is mainly because they do not want to buy and distribute hardware tokens to every user, which is costly. Today, the authenticator apps on your smartphone are modern software tokens. When a website asks you for a code from an authenticator app after your password, you are using two-factor authentication: your password is something you know, and your phone is something you have. That completes Lesson 4.

Slide 27 | Lesson 7: Multi Level Model of Security (about 65 seconds)

Lesson 7

Multi Level Model of Security

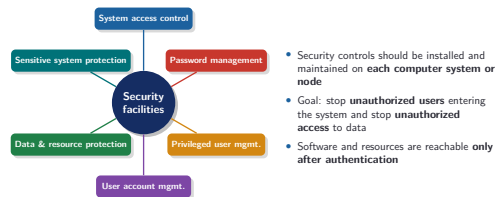
Module 3: Security Goals, Authorization and Access Control

We now begin Lesson 7, the Multi Level Model of Security. In Lesson 4 we learned what we want to protect and why. Now we learn how to protect it in practice. The key word here is multi level. Think about how a bank protects money. There is a guard at the gate, a lock on the door, cameras inside, a strong vault, and an alarm system. If a thief gets past one level, the next level still stops them. A computer system is protected in the same way, with many layers. In this lesson we will learn about access controls and passwords, protecting user accounts, backing up data, firewalls, encryption, intrusion detection systems, physical controls, personnel security and auditing. That is a lot of topics, but each one is simple. At the end, we will put them all together into one picture. So let us start.



Slide 28 | Security System and Facilities (about 64 seconds)

Security System and Facilities



- Security controls should be installed and maintained on **each computer system or node**
- Goal: stop **unauthorized** users entering the system and stop **unauthorized** access to data
- Software and resources are reachable only **after authentication**

Look at the circle in the middle called security facilities. Around it are six areas that every security system must look after. System access control, password management, privileged user management, user account management, data and resource protection, and sensitive system protection. We will study each of these on the next few slides. Now read the bullets on the right. Security controls must be installed and maintained on each computer system or node. A node is simply any computer on the network. The goal is twofold. First, to stop unauthorized users from entering the system at all. Second, to stop users who are inside from reaching data they are not allowed to see. The last point is very important. Software and resources should be reachable only after authentication. In simple words, nobody should be able to use anything until the system has checked who they are.

Slide 29 | System Access Control (about 69 seconds)

System Access Control

Who can get in

- Access to memory, storage, sensitive utilities and files is on a **"need-to-use"** basis
- Access-control software must restrict access; **avoid common passwords** like "administrative", "president", "game"
- Access guidelines are **documented and implemented**
- Each user gets a **unique user ID**

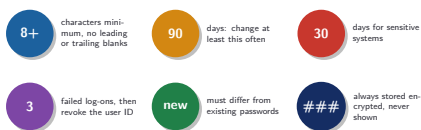
What the system must do

- **Encrypt** stored passwords with proven algorithms
- **Auto time-out** for inactive terminals
- Log an **audit trail** of sensitive actions, and protect it from change or deletion
- Log and monitor **remote users**
- Automate security start-up and shutdown
- Protect sensitive OS files with proven tools

Let us look at system access control in detail. On the left is who can get in. Access to memory, storage, sensitive utilities and files is given on a need-to-use basis. This means you get access only if your job really needs it. Avoid common passwords like administrative, president or game, because attackers try those first. Access rules must be written down and followed. And every user must have a unique user ID, so we always know who did what. On the right is what the system itself must do. It must encrypt stored passwords. It must automatically log out terminals that are left inactive, so nobody can use your computer when you go for tea. It must keep an audit trail of sensitive actions and protect that record from being changed or deleted. It must log and monitor remote users, automate security at start-up and shutdown, and protect important operating system files using proven tools.

Slide 30 | Password Management Rules (about 65 seconds)

Password Management Rules



Also

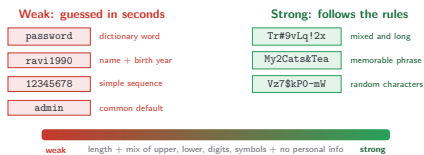
Do not share, display or print passwords · avoid easy-to-guess passwords · resist **dictionary attacks** and known cracking tools

Passwords are still the most common protection, so we must manage them well. Look at the six circles. Eight plus: a password must have at least eight characters, with no blank spaces at the beginning or end. Ninety: passwords must be changed at least every ninety days. Thirty: for sensitive systems, change them every thirty days. Three: after three failed log-on attempts, the user ID should be revoked, or blocked. This stops attackers who try many guesses. New: a new password must be different from the old ones. And the hash symbols show that passwords must always be stored in encrypted form, never in plain text. Now read the red box. Do not share, display or print passwords. Avoid passwords that are easy to guess. And the system should resist dictionary attacks, where an attacker tries every word from a dictionary, and also known password-cracking tools.



Slide 31 | Weak vs. Strong Passwords (about 69 seconds)

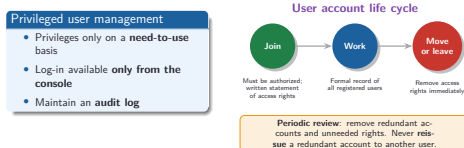
Weak vs. Strong Passwords



Let us make this practical. On the left are weak passwords, which can be guessed in seconds. The word password itself is a dictionary word. Ravi 1990 is a name plus a birth year, which anyone who knows you can guess. One two three four five six seven eight is a simple sequence. And admin is a common default password. Please never use these. On the right are strong passwords. The first one is long and mixes capital letters, small letters, numbers and symbols. The second one, My 2 Cats and Tea, is a memorable phrase with a number and a symbol, so it is easy for you to remember but hard for others to guess. The third one is random characters. Now look at the bar at the bottom. A password moves from weak to strong when it is long, mixes upper case, lower case, digits and symbols, and does not contain personal information.

Slide 32 | Privileged Users and User Accounts (about 70 seconds)

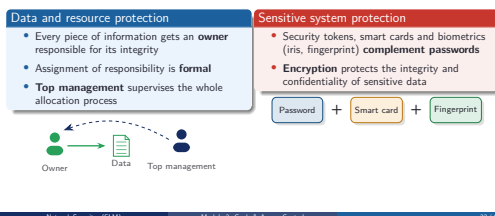
Privileged Users and User Accounts



Some users have special powers, like system administrators. These are called privileged users. Look at the blue box on the left. Privileges must be given only on a need-to-use basis. Privileged users should log in only from the console, which is the main terminal, not from anywhere. And an audit log of their actions must be kept. Why so strict? Because one mistake or misuse by an administrator can damage the whole system. Now look at the user account life cycle on the right. When a person joins, their account must be authorized, with a written statement of their access rights. While they work, a formal record of all registered users is kept. When they move to another department or leave, their access rights must be removed immediately. Read the box at the bottom. Accounts must be reviewed regularly to remove unused accounts and extra rights. And an old account must never be given to another user.

Slide 33 | Data, Resource and Sensitive System Protection (about 64 seconds)

Data, Resource and Sensitive System Protection

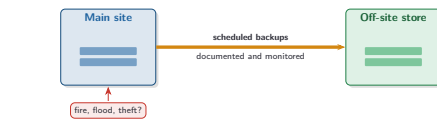


This slide covers two more areas. On the left is data and resource protection. Every piece of information must have an owner, who is responsible for its integrity, that is, keeping it correct. This responsibility must be given formally, in writing, not just by word of mouth. And top management must supervise the whole process. Look at the small diagram: the owner looks after the data, and top management keeps an eye on everything. On the right is sensitive system protection. For important systems, a password alone is not enough. We add security tokens, smart cards and biometrics such as iris and fingerprint scans. Look at the bottom: password plus smart card plus fingerprint. This is the same idea as combining something you know, something you have and something you are. And for sensitive data, we also use encryption to protect its integrity and confidentiality.



Slide 34 | Data Backup and Off-Site Retention (about 72 seconds)

Data Backup and Off-Site Retention



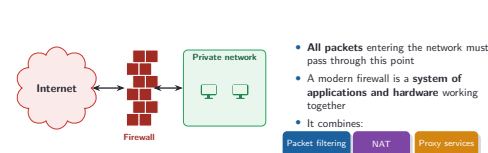
Keep up-to-date backups of critical items

Data files · utilities and programs · databases · operating system code · **encryption keys** · documentation · full and incremental backups on a schedule

Now, a very practical topic: backups. Look at the diagram. On the left is the main site, where the company's computers are. On the right is an off-site store, which is a separate, safe place far away. Scheduled backups are copied from the main site to the off-site store. These backups must be documented and monitored, so we know they are really happening. Why off-site? Look at the red box under the main site. If there is a fire, flood or theft at the main site, both the computers and any backups kept in the same building could be lost. A copy kept far away will still be safe. Now read the blue box. Keep up-to-date backups of all critical items: data files, utilities and programs, databases, operating system code, encryption keys and documentation. Use both full and incremental backups on a fixed schedule. A good habit for you too: keep a copy of your project work in more than one place.

Slide 35 | Firewall: The First Line of Defence (about 68 seconds)

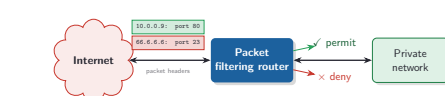
Firewall: The First Line of Defence



Now we come to the firewall. Look at the diagram. On the left is the Internet, which is open to everyone. On the right is the private network of an organization. In between is a brick wall, the firewall. All packets, which are small pieces of data, entering or leaving the network must pass through this one point. The name comes from buildings, where a firewall is a strong wall that stops a fire from spreading from one part to another. Here it stops attacks from spreading from the Internet into our network. Read the bullets on the right. A modern firewall is not just one box. It is a system of applications and hardware working together. It combines three things: packet filtering, network address translation or NAT, and proxy services. In the next two slides, we will look at packet filtering and proxy services, which are the two main types of firewall.

Slide 36 | Packet Filtering Router (about 71 seconds)

Packet Filtering Router



How it works

Looks at the header information of each packet and permits or denies it based on simple rules.

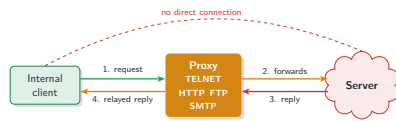
- The first type of firewall used by many organizations
- Usually implemented on a router
- Fast, but sees only headers, not content

The first type of firewall is the packet filtering router. Look at the diagram. Packets come from the Internet to the packet filtering router, which decides whether each packet may enter the private network. How does it decide? Read the blue box. It looks only at the header of each packet. The header is like the address written on an envelope. It shows where the packet came from, where it is going, and which port or service it wants. The router permits or denies the packet using simple rules. In our example, the packet from 10.0.0.9 to port 80, which is for web traffic, is permitted. The packet from 66.6.6.6 to port 23, which is for old remote login, is denied. Now read the bullets. This was the first type of firewall used by many organizations, and it usually runs on a router. It is fast, but its weakness is that it sees only the envelope, not the letter inside.



Slide 37 | Proxy Server (Application Gateway) (about 71 seconds)

Proxy Server (Application Gateway)



- Software that **intercepts** traffic destined for a given application and acts as a **man-in-the-middle**
- The internal client **never connects directly** to the external server
- Can make decisions based on **more than the header**, so it is more secure than a pure packet filter

The second type of firewall is the proxy server, also called an application gateway. Follow the numbers in the diagram. Step one: the internal client sends a request to the proxy. Step two: the proxy forwards the request to the server on the client's behalf. Step three: the server replies to the proxy. Step four: the proxy relays the reply back to the client. Notice the red dashed line at the top. There is no direct connection between the client and the outside server. The proxy acts as a middle-man. Think of a receptionist in an office. Visitors do not walk straight into the manager's room. They talk to the receptionist, who passes messages in and out. Read the bullets. The proxy intercepts traffic for a given application, such as web, email or file transfer. Because it can look at more than just the header, it can make smarter decisions, so it is more secure than a simple packet filter.

Slide 38 | Firewall Characteristics (about 68 seconds)

Firewall Characteristics

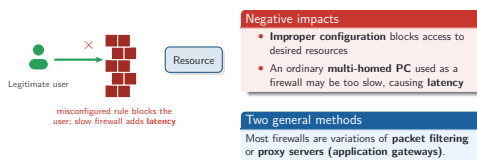
1. All traffic, inside->outside, passes through it
2. Only traffic authorized by the local policy passes
3. The firewall itself is immune to penetration
4. Uses various access-control methods
5. Service control: which Internet services are used
6. Direction control: which way a service request flows
7. User control: access based on permissions
8. Behaviour control: stops malpractice on secured data
9. Must itself be strong, or it is useless

Inbound data is checked to be from an **authenticated user**; outbound data is checked to be going to an **authenticated person**.

This slide lists nine characteristics of a good firewall. Let me go through them simply. One: all traffic between inside and outside must pass through the firewall. Two: only traffic allowed by the local security policy may pass. Three: the firewall itself must be immune to attacks. Four: it uses various access-control methods. Five: service control, which decides which Internet services can be used. Six: direction control, which decides in which direction a service request may flow. Seven: user control, which gives access based on each user's permissions. Eight: behaviour control, which stops misuse of protected data. And nine: the firewall must itself be strong, otherwise it is useless. A weak guard is no guard at all. Finally, read the line at the bottom. Data coming in is checked to make sure it is from an authenticated user, and data going out is checked to make sure it is going to an authenticated person.

Slide 39 | When a Firewall Hurts (about 68 seconds)

When a Firewall Hurts

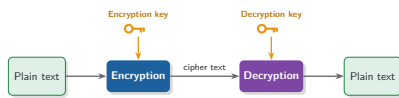


A firewall is very useful, but it can also cause problems. Look at the diagram. A legitimate user is trying to reach a resource, but the firewall blocks them, shown by the red cross. Read the red box on the right. There are two negative impacts. First, improper configuration. If the rules are set wrongly, the firewall may block access to resources that people really need. So a badly configured firewall can stop genuine work, which hurts availability. Second, if an ordinary multi-homed PC, which is a normal computer with more than one network card, is used as a firewall, it may be too slow. This causes latency, which means delay. Everyone's Internet becomes slow. Now look at the blue box. Most firewalls are variations of the two general methods we just studied: packet filtering, or proxy servers. The lesson for us: a firewall must be configured carefully and must have enough power.



Slide 40 | Encryption in the Security System (about 64 seconds)

Encryption in the Security System



Why encryption matters

- Central to all security mechanisms
- Gives **confidentiality** of data
- Some protocols rely on it for **availability**

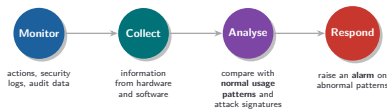
The cost

Encrypted data is **bigger**, so it needs more **bandwidth**, and devices need extra power to encrypt and decrypt.

Next, let us see where encryption fits in our multi-level model. You already know the basic idea from Module 1. Look at the diagram. Plain text goes into encryption, which uses an encryption key. Out comes cipher text, which nobody can read. At the other end, decryption uses the decryption key to turn the cipher text back into plain text. Now read the blue box on the left. Encryption is central to all security mechanisms. It gives confidentiality of data, because a stolen file is useless without the key. Some protocols also rely on it for availability. But encryption has a cost, as the red box explains. Encrypted data is usually bigger, so it needs more bandwidth to send. Devices also need extra processing power to encrypt and decrypt. So, like every security measure, encryption must be used wisely, balancing security with speed and cost.

Slide 41 | Intrusion Detection System (IDS) (about 68 seconds)

Intrusion Detection System (IDS)



What an IDS is

A combination of **hardware and software** that monitors and analyses activity to **detect attacks or intrusions**. Some respond automatically; some use scanners for vulnerability analysis.

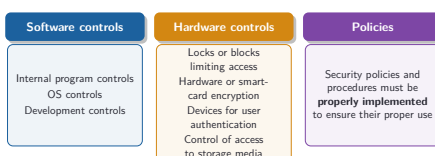
What an IDS cannot do

It **cannot stop crime**. It can only help prevent it and **provide evidence** for investigation.

Now let us learn about the Intrusion Detection System, or IDS. An intrusion is when someone enters a system without permission. Follow the four circles. First, the IDS monitors actions, security logs and audit data. Second, it collects information from hardware and software. Third, it analyses this information, comparing it with normal usage patterns and known attack signatures. Fourth, if it finds something abnormal, it responds by raising an alarm. Think of a burglar alarm in a house. It does not lock the doors, but it watches, and it rings loudly when something unusual happens. Read the blue box. An IDS is a combination of hardware and software. Some can respond automatically, and some scan the system for weaknesses. Now read the red box carefully. An IDS cannot stop crime by itself. It helps prevent it, and it provides evidence for investigation. That is why we use it together with firewalls and other controls.

Slide 42 | Software, Hardware and Policy Controls (about 67 seconds)

Software, Hardware and Policy Controls



Controls are the tools that reduce vulnerabilities. This slide shows three types. On the left are software controls. These include internal program controls, which are checks built into programs, operating system controls, such as user permissions, and development controls, which are good practices used while building software. In the middle are hardware controls. These include locks or blocks that limit access, encryption done by hardware or smart cards, devices that authenticate users, such as fingerprint readers, and control over who can use storage media like disks and pen drives. On the right are policies. Your study material says something important here. Security policies and procedures must be properly implemented to ensure their proper use. A policy written on paper but never followed is useless. For example, a college may have a rule that lab computers are only for academic work, but it only helps if someone actually checks and enforces it.



Slide 43 | Physical Controls (about 67 seconds)

Physical Controls



- Easy to implement, effective and less costly
- Locks on doors; **guards** at entry and exit points
 - Backup copies of critical software and data
 - Access control and media control
 - Precautions against **water and fire** damage
 - Air conditioning
 - Site planning that minimizes **natural disaster** risk

Now let us look at physical controls. These protect the actual building and equipment. Look at the picture of the building. You can see a lock on the door, a guard at the entrance, air conditioning, fire protection, and backups kept safely. Read the green box. Physical controls are easy to implement, effective and less costly. Let me go through the list. Locks on doors, and guards at entry and exit points, so that strangers cannot just walk in. Backup copies of important software and data. Access control and control of storage media, so that nobody can walk out with a hard disk. Precautions against water and fire damage. Air conditioning, because computers can fail if they get too hot. And site planning, which means choosing a location with low risk of natural disasters like floods. Remember, the best software security is useless if someone can simply carry away the server.

Slide 44 | System Security and Virus Controls (about 68 seconds)

System Security and Virus Controls

System security

International security standards: most vendors now build their security facilities to these standards.



Computer virus controls

- Keep **updated** virus protection and detection software
- Scan **internal and external** drives regularly
- Screen all diskettes and software with a virus scanner **before loading**



This slide covers two more controls. On the left is system security. Read the blue box. Today, there are international security standards, and most computer vendors build their security facilities according to these standards. This is good for us, because it means products come with a basic level of security already built in. On the right are computer virus controls. You will study viruses in detail in Module 4, but here are the basic rules. Keep your virus protection and detection software updated. An old antivirus cannot catch new viruses. Scan both internal and external drives regularly. And screen all diskettes and software with a virus scanner before loading them. Today we would say pen drives and downloaded files instead of diskettes. Look at the small diagram at the bottom: a file passes through the scanner first, and only then reaches the computer. Please follow this habit with your own laptops and phones.

Slide 45 | Personnel Security (about 68 seconds)

Personnel Security



Definition

Everything involving **employees**, who are potential elements of security breaches: hiring, training, monitoring them, and handling their departure.

Most breaches are caused by **people**, and the most common perpetrators are the **legitimate users** of the system.



Now we come to people. Personnel security means everything to do with employees, because employees can be part of a security breach. Look at the four circles. It covers hiring, which means checking a person's background before giving them a job. Training, which means teaching them safe practices. Monitoring, which means watching for unusual behaviour. And departure, which means removing their access the moment they leave. Now look at the pie chart on the right. It shows that more than eighty percent of incidents are caused by internal users. Read the line at the bottom. Most security breaches are caused by people, and the most common culprits are the legitimate users of the system. This may surprise you. We usually imagine a hacker in a dark room far away. But very often, the problem is someone inside who is careless, untrained or unhappy. That is why training and monitoring staff is so important.



Slide 46 | Auditing (about 70 seconds)

Auditing

```

security.log
08:00 ravi login OK
09:00 sita login OK
02:11 admin login FAIL
02:12 admin login FAIL
02:13 admin login FAIL
02:14 ravi login from 3 places
03:00 shutdown_db-server
  
```

- A tedious process that needs a good eye for detail
- Track everyone who logs on and off
- Audit movement of critical files, attempted deletions, and access to mission-critical data

Red flags

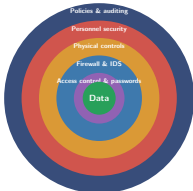
Multiple bad log-on attempts - one account logging in from many places at once - attempted shutdown of critical servers

An organization that skips its logs may be unable to tell the legal agencies that an incident really happened.

The last control is auditing. Auditing means regularly checking the records of what happened in the system. Look at the sample security log on the left. At nine in the morning, Ravi and Sita log in normally. But look at the lines in the red box. At two in the morning, someone tries to log in as admin and fails three times. Then Ravi's account logs in from three places at the same time. Then someone tries to shut down the database server. These are red flags, signs that something is wrong. Read the bullets. Auditing is tedious and needs a good eye for detail. We must track everyone who logs on and off, and watch the movement of critical files, attempts to delete them, and access to important data. Finally, read the last line. If an organization does not check its logs, it may not even be able to prove to the police that an incident happened.

Slide 47 | Putting It Together: The Multi-Level Model (about 67 seconds)

Putting It Together: The Multi-Level Model



Defence in depth

No single control is perfect. Security works in layers: if an attacker gets past one, the next one is still there.

- Lesson 4 decides what to protect and why
- Lesson 7 gives the facilities to protect it at every level

Now let us put everything together. Look at the circles on the left, like the rings of an onion. At the centre, in green, is our data, which is the most valuable thing. Around it is access control and passwords. Then firewall and IDS. Then physical controls. Then personnel security. And on the outside, policies and auditing. Read the blue box. This idea is called defence in depth. No single control is perfect. A password can be stolen, a firewall can be misconfigured, a guard can be tricked. But when we have many layers, if an attacker gets past one layer, the next layer is still there to stop them. Now read the bullets. Lesson 4 helped us decide what to protect and why. Lesson 7 gave us the facilities to protect it at every level. If you remember this one picture, you will remember the whole of Module 3.

Slide 48 | Module 3 Summary (about 64 seconds)

Module 3 Summary

Lesson 4: Security and Authorization

- Goals: integrity, confidentiality, availability
- Risk analysis: assets, threats, impact
- Threats, vulnerabilities and controls
- Method, opportunity, motive
- Know, have, are; MAC vs. DAC; tokens

Lesson 7: Multi Level Model of Security

- Access, password and account management
- Data, resource and sensitive system protection
- Backups, firewalls, encryption, IDS
- Software, hardware and physical controls
- Personnel security and auditing

Review questions

1. Discuss the goals of computer security.
2. What are the security problems and requirements?
3. Explain threats and vulnerabilities.
4. Write a short note on user authentication.
5. Explain security systems and facilities in network security.

Let us quickly summarize what we learned. From Lesson 4, look at the blue box. We learned the three goals: integrity, confidentiality and availability. We learned risk analysis in three steps: identify assets, threats and impact. We learned the difference between threats, vulnerabilities and controls. We learned that an attacker needs method, opportunity and motive. And we learned authentication: something you know, have and are, MAC and DAC, and tokens. From Lesson 7, look at the green box. We learned access, password and account management, data and sensitive system protection, backups, firewalls, encryption and IDS, software, hardware and physical controls, and finally personnel security and auditing. Now look at the red box. These are the five review questions from your study material. Please write answers to all five in your notebook before our next class. They are very likely to come in your examination.



Slide 49 | References (about 66 seconds)

References

- 1 William Stallings, *Cryptography and Network Security*, PHI Publishers.
- 2 Charlie Kaufman, Radia Perlman, *Network Security*, Pearson Education.
- 3 Bruce Schneier, *Applied Cryptography*, John Wiley & Sons.
- 4 Roberta Bragg, *Network Security: The Complete Reference*, TMH.

Thank You! Questions?

Network Security (SLM)

Module 3: Goals & Access Control

49 / 49

Finally, here are the reference books for this module. The first is *Cryptography and Network Security* by William Stallings. This is our main textbook, and most of the ideas we discussed today are explained there in more detail. The second is *Network Security* by Charlie Kaufman and Radia Perlman. The third is *Applied Cryptography* by Bruce Schneier. The fourth is *Network Security: The Complete Reference* by Roberta Bragg, which is very good for practical topics like firewalls, passwords and auditing. Before our next class, please read the chapters on access control, authentication and firewalls. Also, try one small exercise at home. Check the passwords you use for your email and social media. Are they strong, by the rules we learned today? If not, please change them. That is real security in practice. Thank you all for your attention. Now, are there any questions? Please feel free to ask.